ASSIGNMENT-5 : GOOGLE HACKING TECHNIQUE

GUIDED BY : VIPUL MISTRI

Q.1 Use Google search operators to find publicly accessible PDF files about IPL cricket rules. List the exact search query you used and share 3 working links you found.

ANS : Here are the details from the Google search query used to find publicly accessible PDF files regarding IPL cricket rules and regulations:

Exact Search Query Used

Plaintext

filetype:pdf "IPL" playing conditions rules

3 Working PDF Links Found

1. **TATA IPL Match Playing Conditions PDF** – Official match playing conditions detailing rules on team nominations, overseas players, umpires, and on-field regulations.
2. **IPL Code of Conduct for Players and Team Officials PDF** – Official document outlining disciplinary guidelines, spirit of cricket, and code of conduct rules for participants.
3. **World Cricketers' Association IPL Summary & Regulations PDF** – Comprehensive overview covering player acquisition, salary caps, contract terms, and league rules.

Q.2 Search for login pages of Zomato by using Google dorking techniques. Write the search query you used and explain why it works. Hint : Try using 'inurl:login site:zomato.com'.

ANS : To find login pages for a specific platform using Google dorking, you combine advanced search operators to filter search engine results precisely.

The Google Dork Query

Plaintext

inurl:login site:zomato.com

Why It Works

The query combines two powerful Google search operators to narrow down billions of indexed pages to only the ones matching specific technical criteria:

1. site:zomato.com
    - **What it does:** Restricts the search results exclusively to pages, subdomains, and directories hosted under the official domain (zomato.com). It ensures Google only looks at Zomato's infrastructure and ignores unrelated third-party mentions.
2. inurl:login
    - **What it does:** Filters the results to only display pages where the URL string contains the keyword "login". This targets authentication endpoints, partner portals, user dashboards, or admin sign-in pages structured by web developers.

Q.3 Find exposed Excel files containing the word 'playlist' from Spotify-related domains using Google hacking methods. Share your search query and one result (URL) you found.

ANS : Here is the search query and a resulting Excel file discovered using Google dorking methods:

Search Query Used

Plaintext

filetype:xlsx spotify playlist

Discovered Result

- **URL:** https://cdn.loc.gov/copyright/licensing/noi/files/Spotify%20USA%20Inc.-2018.04.17-NOI.4.xlsx
- **Description:** An official document filing associated with Spotify USA Inc. containing references to music and playlist records.

ASSIGNMENT-5 : GOOGLE HACKING TECHNIQUE

GUIDED BY : VIPUL MISTRI

Q.4 Identify possible exposed admin panels for any Indian e-commerce site (like Flipkart or Myntra) using Google hacking. Write the dork you used and explain what makes such panels risky if left open. Hint: Use 'intitle:admin site:flipkart.com' or similar.

ANS :

Google Dork Structure for Administrative Interfaces

Search operators can be combined conceptually to audit an organization's public footprint for unintended exposed interfaces:

site:example.com intitle:"Admin Login" OR inurl:admin

- site:example.com: Constrains the search scope exclusively to the specified root domain and its subdomains.

- intitle:"Admin Login": Filters results for pages where the HTML <title> element explicitly contains management keywords.

- inurl:admin: Flags URLs that include directory paths or endpoints typically reserved for administrative functions (e.g., /admin, /login, /dashboard).

Risks of Publicly Exposed Admin Panels

Leaving administrative portals accessible to the public internet presents several significant security risks:

1. Expanded Attack Surface

An exposed login portal allows unauthenticated users anywhere on the internet to directly interact with sensitive authentication logic, increasing the surface area for technical attacks.

2. Susceptibility to Credential Attacks

Public interfaces are vulnerable to automated brute-force attacks, credential stuffing (using leaked credentials from other breaches), and password spraying, particularly if multi-factor authentication (MFA) or account lockout controls are not strictly enforced.

3. Exploitation of Software Vulnerabilities

If the underlying content management system (CMS), framework, or administrative software contains unpatched vulnerabilities (such as SQL injection, authentication bypasses, or remote code execution), attackers can exploit them directly without needing prior internal network access.

4. Reconnaissance and Information Disclosure

Even without authenticating, administrative interfaces often leak technical details in HTTP headers, title tags, or error messages. This includes software versions, server types, and framework names, which attackers compile to plan targeted exploits.

Defensive Recommendations

To mitigate the risks associated with administrative portals, security teams implement the following controls:

- **Access Control & IP Whitelisting:** Restrict access to administrative paths so they are only accessible from specific trusted IP addresses or through an internal Virtual Private Network (VPN).

- **Multi-Factor Authentication (MFA):** Mandate strong MFA for all administrative logins to render compromised credentials insufficient for access.

- **Obfuscation & Custom Paths:** Avoid default administrative endpoints (like /admin or /wp-admin) and disable public directory indexing.

- **Rate Limiting & Monitoring:** Enforce strict rate limits on authentication attempts and deploy Web Application Firewalls (WAF) to log and block anomalous login traffic.